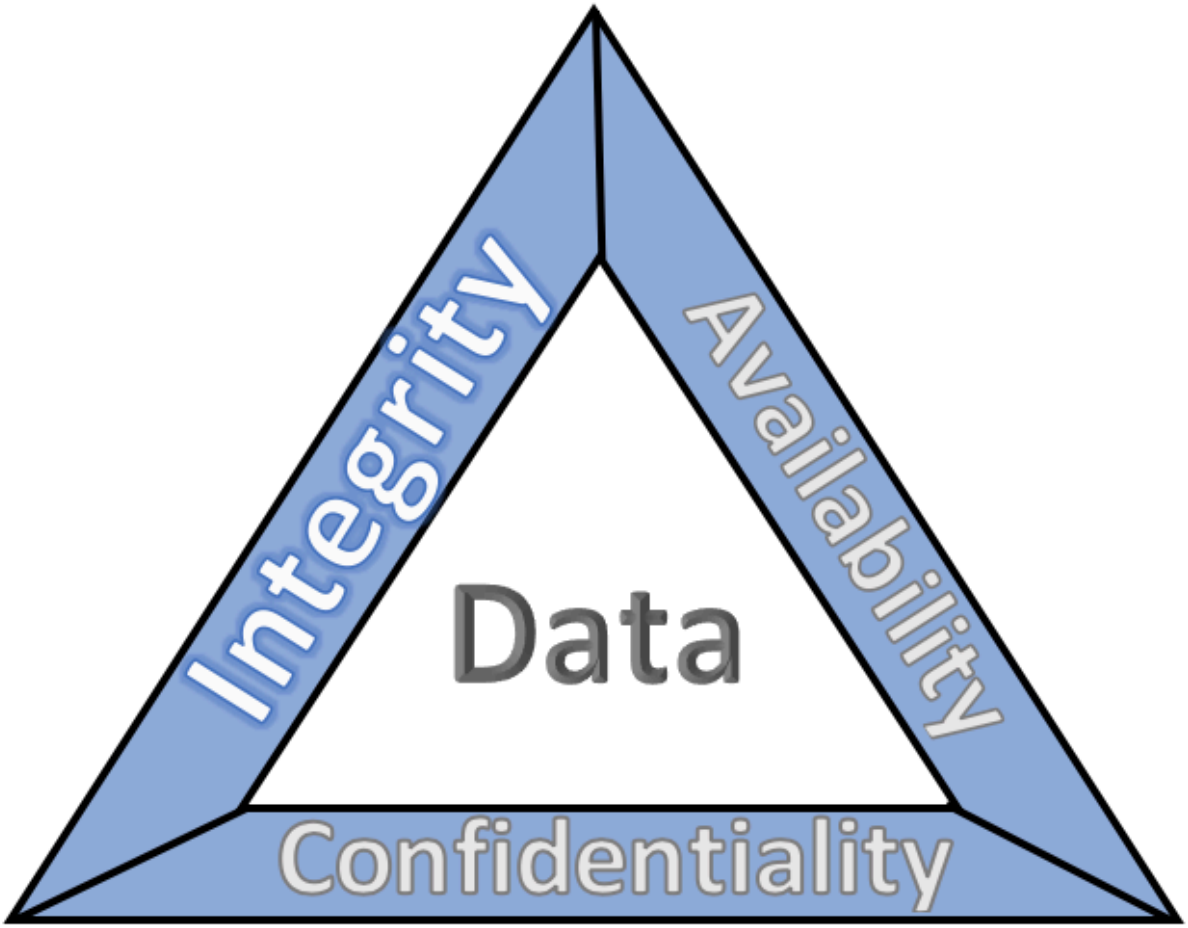
Principles of Security

The CIA Triad



The CIA triad is unlike a traditional model where you have individual sections; instead, it is a continuous cycle. Whilst the three elements to the CIA triad can arguably overlap, if even just one element is not met, then the other two are rendered useless

Confidentiality

This element is the protection of data from unauthorised access and misuse. Organisations will always have some form of sensitive data stored on their systems. To provide confidentiality is to protect this data from parties that it is not intended for.

Integrity

The CIA triad element of integrity is the condition where information is kept accurate and consistent unless authorized changes are made. It is possible for the information to change

because of careless access and use, errors in the information system, or unauthorised access and use.

integrity is maintained when the information remains unchanged during storage, transmission, and usage not involving modification to the information. Steps must be taken to ensure data cannot be altered by unauthorised people

Availability

In order for data to be useful, it must be available and accessible by the user.

Availability is very often a key benchmark for an organisation. For example, having 99.99% uptime on their websites or systems. When a system is unavailable, it often results in damage to an organisations reputation and loss of finances. Availability is achieved through a combination of many elements, including:

- Having reliable and well-tested hardware for their information technology servers (i.e. reputable servers)
- Having redundant technology and services in the case of failure of the primary
- Implementing well-versed security protocols to protect technology and services from attack

Principles of Privileges

It is vital to administrate and correctly define the various levels of access to an information technology system individuals require.

The levels of access given to individuals are determined on two primary factors:

- The individual's role/function within the organisation
- The sensitivity of the information being stored on the system

Two key concepts are used to assign and manage the access rights of individuals: Privileged Identity Management (PIM) and Privileged Access Management (or PAM for short).

PIM is used to translate a user's role within an organisation into an access role on a system.

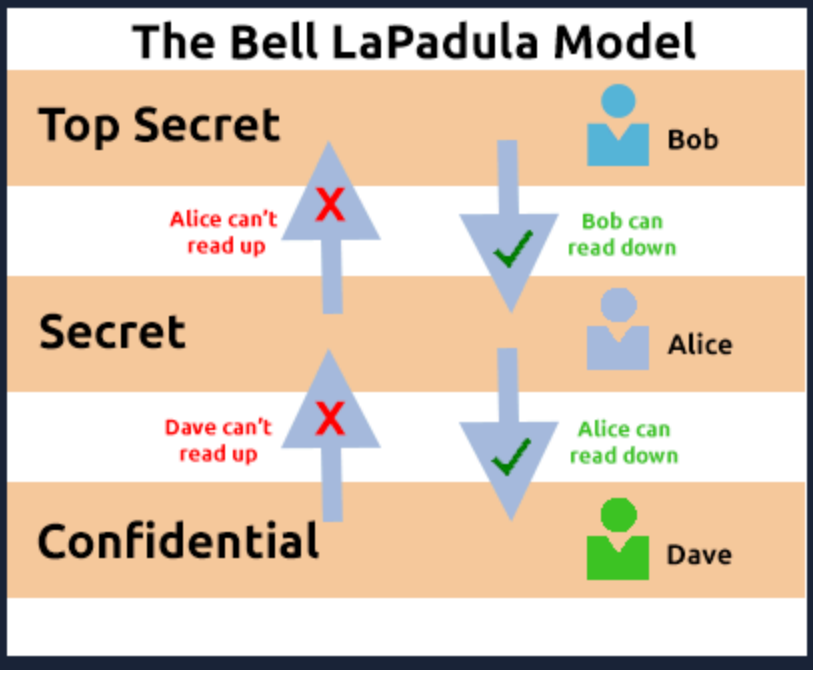
PAM is the management of the privileges a system's access role has, amongst other things

Security Models Continued

The Bell-La Padula Model

The Bell-La Padula Model is used to achieve confidentiality. This model has a few assumptions, such as an organisation's hierarchical structure it is used in, where everyone's responsibilities/roles are well-defined.

Advantages	Disadvantages
Policies in this model can be replicated to real-life organisations hierarchies (and vice versa)	Even though a user may not have access to an object, they will know about its existence -- so it's not confidential in that aspect.
Simple to implement and understand, and has been proven to be successful.	The model relies on a large amount of trust within the organisation.

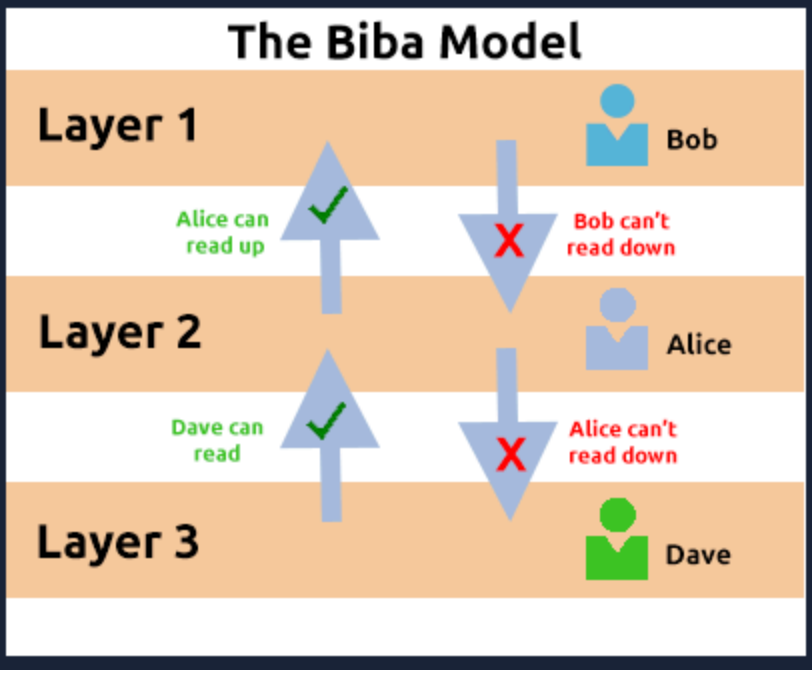


Biba Model

The Biba model is arguably the equivalent of the Bell-La Padula model but for the integrity of the CIA triad.

This model applies the rule to objects (data) and subjects (users) that can be summarised as "no write up, no read down". This rule means that subjects **can** create or write content to objects at or below their level but **can only** read the contents of objects above the subject's level.

Advantages	Disadvantages
This model is simple to implement.	There will be many levels of access and objects. Things can be easily overlooked when applying security controls.
Resolves the limitations of the Bell-La Padula model by addressing both confidentiality and data integrity.	Often results in delays within a business. For example, a doctor would not be able to read the notes made by a nurse in a hospital with this model.



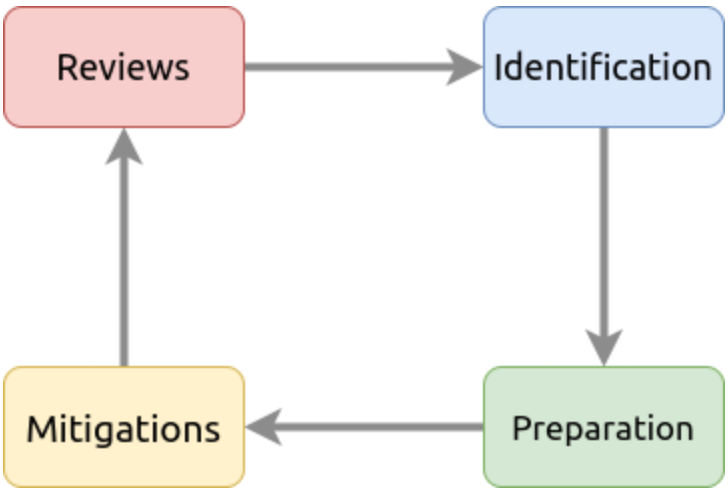
Threat Modelling & Incident Response

Threat modelling is the process of reviewing, improving, and testing the security protocols in place in an organisation's information technology infrastructure and services.

The threat modelling process is very similar to a risk assessment made in workplaces for employees and customers. The principles all return to:

- Preparation
- Identification

- Mitigations
- Review



An effective threat model includes:

- Threat intelligence
- Asset identification
- Mitigation capabilities
- Risk assessment

there are frameworks such as **STRIDE** (**S**poofing identity, **T**ampering with data, **R**epudiation threats, **I**nformation disclosure, **D**enial of Service and **E**levation of privileges)

PASTA (**P**rocess for **A**ttack **S**imulation and **T**hreat **A**nalysis) infosec never tasted so good!. Let's detail STRIDE below.

STRIDE:

Principle	Description
Spoofing	This principle requires you to authenticate requests and users accessing a system. Spoofing involves a malicious party falsely identifying itself as another. Access keys (such as API keys) or signatures via encryption helps remediate this threat.
Tampering	By providing anti-tampering measures to a system or application, you help provide integrity to the data. Data that is accessed must be kept integral and accurate. For example, shops use seals on food products.
Repudiation	This principle dictates the use of services such as logging of activity for a system or application to track.
Information Disclosure	Applications or services that handle information of multiple users need to be appropriately configured to only show information relevant to the owner.
Denial of Service	Applications and services use up system resources, these two things should have measures in place so that abuse of the application/service won't result in bringing the whole system down.
Elevation of Privilege	This is the worst-case scenario for an application or service. It means that a user was able to escalate their authorization to that of a higher level i.e. an administrator. This scenario often leads to further exploitation or information disclosure.

Incidents are classified using a rating of urgency and impact. Urgency will be determined by the type of attack faced, where the impact will be determined by the affected system and what impact that has on business operations.

Urgency \ Impact	High	Medium	Low
High	1	2	3
Medium	2	3	4
Low	3	4	5

To successfully solve an incident, these steps are often referred to as the six phases of Incident Response that takes place, listed in the table below:

Action	Description
Preparation	Do we have the resources and plans in place to deal with the security incident?
Identification	Has the threat and the threat actor been correctly identified in order for us to respond to?
Containment	Can the threat/security incident be contained to prevent other systems or users from being impacted?
Eradication	Remove the active threat.
Recovery	Perform a full review of the impacted systems to return to business as usual operations.
Lessons Learned	What can be learnt from the incident? I.e. if it was due to a phishing email, employees should be trained better to detect phishing emails.